

ByteStreams Intranet — SAML SSO Setup Checklist

bytestreams.info ↔ Google Workspace IdP

1. Prerequisites

- ☐ Node.js 18+ installed
- ☐ MongoDB instance available (local or cloud — e.g., MongoDB Atlas)
- ☐ Google Workspace super admin access (@bytestreams.ai)
- ☐ Domain bytestreams.info pointed to your server
- ☐ SSL/TLS certificate for bytestreams.info (required for SAML)

2. Generate SP Certificates

```
npm run generate-certs
```

This creates:

- ☐ certs/sp-cert.pem — public cert (share with Google)
- ☐ certs/sp-key.pem — private key (never share, gitignored)

3. Google Workspace Admin Console

Path: admin.google.com → Apps → Web and mobile apps → Add App → Add custom SAML app

Step 1 — App Details

- ☐ App name: **ByteStreams Intranet**
- ☐ Click **Continue**

Step 2 — Google IdP Details

⚠ Important

Download the IdP certificate in this step. You cannot retrieve it later without starting over.

- ☐ Copy the **SSO URL** → save for `.env SAML_ENTRY_POINT`
- ☐ Note the **Entity ID**
- ☐ Click "**Download Certificate**" → save as `certs/google-idp-cert.pem`
- ☐ Click **Continue**

Step 3 — Service Provider Details

- ☐ ACS URL: `https://bytestreams.info/auth/sso/acs`
- ☐ Entity ID: `https://bytestreams.info`
- ☐ Start URL: `https://bytestreams.info/auth/sso/login`
- ☐ Signed response: ☒ Checked
- ☐ Name ID format: **EMAIL**
- ☐ Name ID: Basic Information → Primary email
- ☐ Click **Continue**

Step 4 — Attribute Mapping

- ☐ First name → `firstName`
- ☐ Last name → `lastName`
- ☐ Primary email → `email`
- ☐ Click **Finish**

Step 5 — Enable

- ☐ Click "**User access**" → ON for everyone → Save

- ☐ Wait 2-5 minutes for propagation

4. Environment Configuration

Create `.env` from template:

```
cp .env.example .env
```

Fill in these values:

- ☐ `NODE_ENV=production`
- ☐ `PORT=3000`
- ☐ `BASE_URL=https://bytestreams.info`
- ☐ `SESSION_SECRET=(generate a random 64-char string)`
- ☐ `MONGO_URI=mongodb://localhost:27017/bytestreams-intranet`
- ☐ `SAML_ENTRY_POINT=(SSO URL from Google Step 2)`
- ☐ `SAML_ISSUER=https://bytestreams.info`
- ☐ `SAML_CALLBACK_URL=https://bytestreams.info/auth/sso/acs`
- ☐ `SAML_IDP_CERT_PATH=./certs/google-idp-cert.pem`
- ☐ `SAML_SP_CERT_PATH=./certs/sp-cert.pem`
- ☐ `SAML_SP_KEY_PATH=./certs/sp-key.pem`

5. Launch

```
npm install npm run dev
```

Verify the flow:

- ☐ Visit `http://localhost:3000`
- ☐ Redirected to Google sign-in page
- ☐ Sign in with `@bytestreams.ai` account
- ☐ Landed on intranet home page
- ☐ User name and email displayed correctly

6. Key Endpoints Reference

Endpoint	Method	Purpose
/login	GET	Login page with Google SSO button
/auth/sso/login	GET	Initiates SAML flow → redirects to Google
/auth/sso/acs	POST	Assertion Consumer Service (Google posts here)
/auth/sso/logout	GET	Destroys session, redirects to Google logout
/auth/sso/metadata	GET	SP metadata XML (give this URL to IdP admin)
/auth/me	GET	Returns current user JSON
/health	GET	Health check (public, no auth required)

7. Certificates Reference

File	Type	Location	Notes
sp-cert.pem	SP Public Cert	certs/	Generated locally. Share with Google if needed.
sp-key.pem	SP Private Key	certs/	NEVER share. Gitignored.
google-idp-cert.pem	IdP Public Cert	certs/	Downloaded from Google Admin Console. Used to validate SAML assertions.

8. Troubleshooting Quick Fixes

Error	Fix
"SAML assertion invalid"	Verify ACS URL in Google Admin matches <code>SAML_CALLBACK_URL</code> exactly
"InResponseTo validation failed"	Check server clock sync (the scaffold allows 5 min skew)
"Certificate mismatch"	Re-download the IdP cert from Google Admin Console — it may have been rotated
403 Access Denied after login	Your email domain isn't in the allowed list — check <code>middleware/auth.js</code> <code>ensureDomain()</code>
Redirect loop on login	Ensure cookies are enabled and secure flag matches your protocol (HTTPS in prod)
"Strategy not initialized"	Cert files missing from <code>certs/</code> — run <code>npm run generate-certs</code> and re-download IdP cert